Security and resilience audit

SinCityNotary Team Tracker v1.3 | 18 October 2026

Verified security and correctness defects were fixed in application code. The audit completed 380 automated assertions across 17 suites, with zero failed assertions. These are targeted checks, not a security certification or proof that every bug is eliminated.

The shared access code, access settings, authentication rules, database schema, existing employee records, permanent IDs and uploaded originals were preserved. Tests used disposable databases, private temporary storage and fictional records. No stress traffic, restore, export, upload, messaging or data-edit action was sent to production.

Verified findings and fixes

Finding and original impact	Severity	Result
Malformed SVG text caused quadratic CPU work during an authorized upload.	High	Fixed: linear suffix validation; original format and download-only handling retained.
Update JSON was fully buffered before rejection; a synthetic 2 MiB stream was consumed.	Medium	Fixed: stop/cancel above 72,000 streamed bytes; retain the 24,000-character ceiling.
Large image/history restore manifests repeatedly scanned entire collections.	Medium	Fixed: indexed image batches, IDs and event counts; valid associations preserved.
A failed backup response stream could terminate the portable Node process.	Medium	Fixed: error-aware pipelines and source cancellation when clients disconnect.
A crafted backup could associate an email confirmation with another employee.	Medium	Fixed for future restores: bind the confirmation to the report/request's permanent employee link.
Email drafts could open using stale recipients; unsafe single-address/header text was accepted.	Medium	Fixed: saved recipient/revision recheck before open/copy; reject unsafe new recipient and subject input.
Invalid encoded IDs, incomplete Unicode and impossible journal dates produced errors or invalid new data.	Low	Fixed: bounded validation errors and new-write validation; historical text is not rewritten.
Short-screen controls, offscreen navigation focus, long text and small touch controls impaired mobile/tablet use.	Medium usability	Fixed in source: scrolling, focus containment, responsive wrapping and touch sizing.
Large galleries repeatedly searched all records; Windows static paths used a hardcoded slash.	Medium functional	Fixed: linear gallery indexes and platform-aware static containment.

Severity describes impact under the stated prerequisites. It is separate from the probability of an incident. Most server findings require an authenticated session; restore findings also require the existing restore authorization and an empty target.

Verification and preservation

Completed checks

Test area	Passed assertions
Core API, security invariants, new validation and concurrency stress	92
Journal, email event handlers, WhatsApp API and portable messaging	63
Images, complete backups, restore rollback and media/stream regressions	45
Frontend state, validation, gallery association and scalable grouping	131
Global search, archived records and session lifecycle	32
Portable HTTP, static paths, security headers, startup and persistence	17
Total across 17 suites	380 passed / 0 failed

The concurrency suite issued 201 synthetic API requests at a maximum of 12 concurrent requests. It found no unexpected 5xx responses, duplicate accepted IDs/tickets or accepted employee/device mismatches. One deliberate storage fault returned a generic 500 as expected. This bounded workload does not establish production capacity, sustained availability or a real-world failure probability.

Media checks exercised 60,000 image entries in 10,000 batches and a separate 1,000-device/10,000-event restore fixture. Index-operation checks confirm linear association lookups. Malformed SVG and stream failures were reproduced before their fixes. Timings vary with the machine and are not service-level guarantees.

The gallery regression used 10,000 records and 10,000 images. It verified one record indexing pass, complete retention, explicit unassigned receipts, upload provenance and first-record lookup semantics. No image was moved to another employee/device or modified by the test.

Mobile and tablet verification limits

Source/CSS constraints were reviewed at widths 320, 360, 390, 768, 820, 1024 and 1280 pixels, including short-height dialogs. Automated checks exercise state and rendered markup; they do not render a real browser. Physical phones/tablets, onscreen keyboards, assistive technology, mail-client launch after asynchronous checks, and actual Windows execution remain unverified. No browser engine or preview was installed as a substitute.

Change boundary

No migrations or access configuration changes were introduced. The authentication module, schema/migration files and Site storage bindings were unchanged. Existing backup roundtrip and rollback checks retained IDs, employee/device relationships, warranty values, original bytes and separate manual confirmation histories. Tests sent no email or WhatsApp message. Documentation, manual and code/download packages were refreshed.

Evidence is retained with the source in qa/security-audit-summary.json, qa/core-audit.json, qa/security-media.json, qa/stress-audit.json, qa/email-ui-audit.json and the existing per-module reports. Type checking passed; publication is verified separately through the hosting deployment result.

Residual risk and likelihood

What can be estimated

A defensible percentage for this tracker's chance of breach cannot be calculated from these targeted tests. There is no calibrated site-specific incident model, attack exposure history or production load experiment. A passed test is evidence about the tested condition; it is not a percentage reduction in real-world risk.

With shared access excluded as requested, remaining application risk is assessed qualitatively as **low to moderate**, with medium confidence. This judgment assumes unchanged trusted hosting, confidential existing access credentials, normal office-scale use and trusted build inputs. It is not an annual or 30-day statistical probability.

Remaining issue	Likelihood assessment and action
Build/lint dependency: braces 3.0.3, CVE-2026-93687 / GHSA-vfj7-8cjw-p6xm	Low observed runtime exposure: no application input path was identified, and the portable runtime excludes it. High upstream severity remains; no published patch is listed. Use trusted build inputs and revisit the upstream fix.
Resource exhaustion from repeated large or expensive authenticated requests	Possible; not quantified. Bounds and linear validators reduce specific amplification paths. They do not provide comprehensive rate/capacity or DDoS protection. No production saturation test was performed.
Original image contents and mobile decoding memory	Possible; not quantified. Signature/container checks are not malware scans or full image decoders. A compressed image can have large decoded dimensions. Original files and metadata were deliberately retained.
Mobile/tablet rendering, external mail apps and Windows execution	Unverified rather than proven safe. Source fixes and automated checks passed, but real device/browser testing remains necessary to establish behavior on a particular device.
Hosting, privileged storage access and unknown vulnerabilities	Not assessed exhaustively. Code tests cannot establish infrastructure resilience, absence of unknown flaws or resistance to a fully privileged storage administrator.

Published probability for the remaining CVE

On 18 October 2026, the GitHub advisory displayed **EPSS 0.757% over the next 30 days** for CVE-2026-93687. EPSS predicts whether that CVE will be exploited in the wild across deployments. It does not estimate the chance that this tracker will be breached, and must not be presented as this site's risk percentage.

The fresh full-lockfile scan reported one high advisory and zero critical advisories. The production dependency scan reported zero known advisories. Package classification was supplemented by portable module-graph and hosted-bundle inspection; it is not a proof of total absence or future safety. Dependencies were retained because no compatible published patch for the remaining finding was identified.

Primary references checked on 18 October 2026

1. GitHub advisory: https://github.com/advisories/GHSA-vfj7-8cjw-p6xm

2. FIRST EPSS definition: https://www.first.org/epss/

3. Upstream discussion and applicability: https://github.com/micromatch/braces/issues/70